LokalBoost

Ringkasan Proyek

Marketplace UMKM × Kreator Pemula — Pay-Per-View, Rekber, dan AI

Disusun	**4 Agustus 2026**
Backend	**65 endpoint · 17 tabel**
Frontend	**24 halaman · 13 komponen**
Pengujian	**53 tes unit · 69 uji asap**
Status	**Berjalan lokal, belum ditayangkan**

Arsitektur & Fitur

Folder: `C:/Users/Lenovo/Documents/INFEST LOMBA`

Apa itu LokalBoost

Marketplace yang mempertemukan **UMKM lokal** dengan **kreator konten pemula**. Tiga gagasan intinya:

1. **Pay-Per-View** — UMKM membayar per tayangan asli, bukan per unggahan. Kreator pemula tanpa portofolio jadi punya jalan masuk.
2. **Rekber (Escrow)** — dana UMKM ditahan platform sampai hasilnya terbukti. Tidak ada pihak yang harus percaya lebih dulu kepada pihak lain.
3. **AI Anti-Fraud** — karena model bayar-per-tayangan hanya masuk akal kalau tayangannya bisa dipercaya.

Sumber kebutuhan: PRD di `ISI dan Fungsi/LokalBoost (1).pdf`. Tiga peran: **UMKM**, **Kreator**, **Admin**.

Ukuran proyek

Backend	65 endpoint, 17 tabel, ±5.300 baris
Frontend	24 halaman, 13 komponen, ±10.900 baris
Pengujian	53 tes unit + 69 pemeriksaan uji asap
Riwayat	6 commit, repo privat `westindolie/lokalboost`

Backend — `lokalboost-api/`

Tumpukan: Node 20 · Express 4 (ESM) · SQLite lewat `better-sqlite3` · JWT (`jsonwebtoken`) · scrypt bawaan Node (bukan bcrypt) · `nodemailer` · `@anthropic-ai/sdk` .

Seluruh identifier dan pesan galat berbahasa Indonesia. Ikuti konvensi itu kalau menambah kode.

Susunan berkas

```
src/
  index.js      titik masuk + pemeriksaan konfigurasi produksi
  app.js        Express, CORS, pembatas laju, penanganan galat terpusat
  config.js     SATU-SATUNYA tempat membaca process.env
  schema.sql    17 tabel, seluruhnya CREATE TABLE IF NOT EXISTS
  lib/          auth.js (scrypt/JWT) · db.js · util.js · batas.js
  routes/       auth kampanye kreator dompet video tayangan ulasan
                notifikasi sengketa ai dashboard admin
  services/     escrow antifraud matchmaker ai surel notifikasi laporan
```

Tabel

`pengguna` `otp` `profil_umkm` `profil_kreator` `kampanye` `kampanye_brief` `lamaran` `dompet` `escrow` `transaksi` `video` `tayangan` `umpan_matchmaker` `ulasan` `notifikasi` `sengketa` `naskah_ai`

Tidak ada ORM — seluruhnya prepared statement mentah. Tidak ada perkakas migrasi; kolom baru ditambahkan lewat helper `tambahKolomBila()` di `lib/db.js`.

Aturan bisnis yang tidak boleh dibalik tanpa sadar

- `prosesPembayaran()` menjalankan deteksi anomali **sebelum** akrual. Begitu tayangan ditandai `dibayar = 1` ia tidak bisa disaring lagi.
- `bayarPemulihan()` sengaja **TIDAK** menjalankan lapis 2 lebih dulu — tayangannya baru dipulihkan admin, menyaringnya lagi berarti membatalkan keputusan manusia di detik yang sama.
- Kreator menerima akrual ke `saldo_tertahan`; dana pindah ke `saldo` hanya saat kampanye ditutup. Penarikan hanya dari `saldo`.
- Tayangan yang disaring **tidak dihapus** (`valid = 0` + kolom `alasan`) — itu bukti untuk sengketa dan banding.
- Komisi platform 5% dipotong dari bagian kreator, bukan ditambahkan ke tagihan UMKM. **Neraca wajib tertutup** — `GET /api/admin/kampanye` menampilkan `selisihNeraca` yang harus selalu nol.
- IP tidak pernah disimpan mentah, hanya hash SHA-256 terpotong (UU PDP).

Frontend — `lokalboost-web/`

React 18 · Vite 5 · Tailwind 3 · React Router 6 · Framer Motion (`motion` v12).

Sumber kebenaran lintas halaman — jangan tulis ulang datanya di halaman:

- `src/api.js` — satu-satunya pintu ke backend, plus hook `useApi(ambil, kunci, {aktif})` yang mengembalikan `{data, memuat, galat, muatUlang}`.

- `src/sesi.jsx` — peran datang dari **token JWT**, bukan dari alamat halaman. Penjaga rute `<Terproteksi peran>` mengalihkan tamu ke `/masuk?lanjut=…`.
- `src/format.js` — rupiah/tanggal/waktuLalu + penerjemah status backend. Jangan format angka sendiri di halaman. Catatan: `persen()` mengembalikan **angka saja**, tanda `%` ditulis manual di JSX.
- `src/draf.jsx` — keadaan wizard kampanye tiga langkah.
- `src/data/pilihan.js` — hanya daftar pilihan tetap. `src/data/mock.js` **sudah dihapus** — seluruh data datang dari API.

Setiap halaman berdata wajib punya tiga keadaan: memuat, gagal (dengan tombol coba lagi), dan kosong. Ketiganya ada di `components/Muat.jsx` dan `ui.jsx`.

Lima fitur AI

Fitur	Jenis	Status
Smart Matchmaker	algoritma murni	✅ jalan
Anti-Fraud	algoritma murni	✅ jalan
Auto-Subtitle	algoritma murni	✅ jalan
Script Generator	Claude + cadangan template	⚠️ pakai template
Auto-Report Summary	Claude + cadangan template	⚠️ pakai template

Smart Matchmaker

Skoring berbobot yang **seluruh komponennya bisa dijelaskan** — penting karena UMKM sasaran awam digital dan butuh tahu *kenapa* seorang kreator direkomendasikan.

Total 100: niche 30 · lokasi 25 · rating 20 · rekam jejak 10 · jangkauan 10 · ketersediaan 5.

Dua keputusan desain yang layak disebut saat presentasi:

- **Cold start** — kreator tanpa ulasan dapat nilai dasar 70%, bukan nol. Memberi nol akan membuat sisi suplai macet selamanya.
- **Wilayah aglomerasi** — penonton Cimahi praktis sama berharganya dengan Bandung bagi warung di Bandung, jadi tidak dihukum penuh seperti kota jauh.

Anti-Fraud (dua lapis)

- **Lapis 1** — aturan per tayangan saat data masuk: pola bot di user-agent, durasi tonton di bawah 25% durasi video, terlalu banyak tayangan dari satu IP, duplikat perangkat dalam 10 menit.

- **Lapis 2** — z-score terhadap volume tayangan per jam **kampanye itu sendiri**, bukan ambang tetap. Alasannya: kampanye target 5.000 dan 25.000 view punya "normal" yang sangat berbeda; ambang tetap akan menghukum kampanye besar dan meloloskan kecurangan pada kampanye kecil.

Script Generator & Auto-Report

Pola hibrida yang disengaja: kalau `ANTHROPIC_API_KEY` ada, permintaan dikirim ke Claude dan hasilnya bertanda `sumber: "llm"`; kalau tidak, jatuh ke penyusun template deterministik bertanda `sumber: "template"`. Alasannya praktis — demo tidak boleh gagal karena Wi-Fi ruangan. Layar menyebutkan sumbernya apa adanya.

Lihat **LokalBoost — status & yang belum lengkap** dan **LokalBoost — rencana pengembangan**.

Status & Yang Belum Lengkap

Diperiksa **4 Agustus 2026** dengan menjalankan servernya, bukan hanya membaca kode.

Sudah selesai dan terbukti jalan

Alur inti

Pendaftaran tiga langkah → verifikasi email → profil → buat kampanye (wizard 3 langkah) → setor dana ke Rekber → kreator melamar / diundang → UMKM menyetujui → unggah video → tayangan tercatat & disaring → laporan hasil → kampanye ditutup → dana cair → ulasan. Sengketa bisa diajukan kapan saja dan diputus admin.

Verifikasi email — benar-benar mengirim surat

`services/surel.js` memakai nodemailer dengan App Password Gmail. **Terbukti:** server mencetak `Kode OTP dikirim lewat smtp.gmail.com`, dan pendaftaran uji benar-benar mengirim email ke inbox sungguhan.

Pengetatan yang dikerjakan 4 Agustus 2026 (sebelumnya seluruh alur OTP bisa dilewati begitu saja):

- `/auth/masuk` **menolak akun belum terverifikasi** (403 + `rincian.perluVerifikasi`), sambil menerbitkan kode baru dan mengantar pengguna ke layar OTP — bukan pesan merah buntu.
- **5 tebakan salah menghanguskan kode** (kolom `otp.percobaan`).
- **Jeda 60 detik** antar permintaan kode + maksimal **5 kode per identitas per jam**. Bersandar pada tabel `otp`, jadi restart server tidak menghapus jedanya.
- `/otp/kirim` menjawab **netral** untuk email terdaftar maupun tidak — tidak bisa dipakai memetakan siapa yang punya akun.
- Email divalidasi bentuknya dan dinormalkan huruf kecil.
- Pembatas laju **60 permintaan/menit per IP** untuk `/api/auth` (`lib/batas.js`, di memori — sah karena `numReplicas: 1`).
- Server **menolak menyala** di produksi kalau `JWT_SECRET` masih nilai bawaan.

Notifikasi

17 pemicu in-app. Lima di antaranya juga dikirim ke inbox: lamaran disetujui, lamaran ditolak, dana cair, sengketa diputus, konten diminta revisi. Lonceng menyegarkan hitungannya tiap 60 detik. Ada sambutan otomatis setelah verifikasi berhasil.

Ruang admin

Ringkasan platform · neraca per kampanye (dengan kolom `selisihNeraca` yang wajib nol) · antrean moderasi konten · verifikasi profil + NIB · buku transaksi · **Ketepatan AI**.

Loop belajar AI

Sebelumnya `batalkanPenyaringan()` menjalankan `alasan = NULL` — menghapus satu-satunya data berlabel yang dimiliki sistem. Sekarang labelnya disimpan (`tayangan.dipulihkan`), keputusan matchmaker dicatat (`umpan_matchmaker`), dan `GET /api/admin/pembelajaran` menghitung tingkat salah-saring per aturan.

Terbukti berputar: memenangkan sengketa memulihkan 79 tayangan, dan laporan langsung menunjukkan aturan IP-berulang salah **31,5%** serta menandainya perlu ditinjau — angka yang sebelumnya mustahil diketahui.

Belum lengkap

Penghalang untuk tayang online

- **Belum di-deploy sama sekali.** Masa percobaan Railway habis (butuh paket berbayar). Riset 4 Agustus 2026: Fly.io menghapus tier gratis untuk org baru; Render tidak mengizinkan disk permanen di paket gratis (plus tidur 15 menit); Koyeb menutup tier gratisnya setelah diakuisisi Mistral; Northflank paling mendekati tapi mewajibkan kartu. **Tidak ada yang gratis + tanpa kartu + punya disk permanen sekaligus.** Keputusan: demo dari laptop.
- **Situs `lokalboost-web.vercel.app` yang tayang masih build lama berbasis data tiruan** — bundelnya berisi **nol** kemunculan `/api/` . Situs itu tidak pernah memanggil backend. Kalau ada gejala aneh, cek dulu apakah yang dibuka situs Vercel atau localhost.

Fitur yang belum ada

- **AI generatif belum menyala** — `ANTHROPIC_API_KEY` kosong, jadi Script Generator & Auto-Report memakai template. Jalur LLM-nya **belum pernah dieksekusi sekali pun**, jadi bentuk panggilan API-nya belum terbukti benar.
- **Tidak ada ubah/lupa kata sandi.** Masuk-dengan-OTP menambal sebagian, tapi kata sandi tidak bisa diganti selamanya.
- **2FA penarikan masih boneka** — `escrow.js` hanya memeriksa `kodeOtp` tidak kosong; string apa pun lolos, tidak pernah dicocokkan ke tabel `otp` . Ini lubang paling layak ditutup berikutnya.
- **Tidak ada penyedia SMS.** Karena itu pendaftaran kini **wajib email**; nomor HP hanya kontak, bukan identitas masuk. Jangan hidupkan lagi opsi HP tanpa menyambungkan SMS lebih dulu — akun tanpa email = akun terkunci selamanya.
- **Tidak ada payment gateway.** Setor dana dan penarikan mencatat mutasi di basis data. Titik integrasinya sudah terisolasi di `escrow.js` .

- **Tidak ada speech-to-text asli.** Auto-Subtitle memecah naskah yang sudah ada menjadi potongan bertimestamp.
- **Video disimpan di folder lokal**, dilayani statis Express — bukan cloud/CDN.
- **Verifikasi NIB belum sungguhan** — admin mencatat nomornya, tidak ada pemeriksaan ke sistem pemerintah.

Utang keamanan yang diketahui

- JWT disimpan di `localStorage` (terjangkau XSS). Wajar untuk SPA seperti ini, tapi itu kompromi yang sedang berlaku.
- `JWT_SECRET` produksi pernah tertulis di `DEPLOY.md` dan **ikut riwayat git** — nilainya harus dianggap hangus selamanya. Barisnya sudah diganti jadi perintah pembuatan.
- Tombol akun demo **Admin** sudah dihapus dari halaman Masuk publik. Akun UMKM & Kreator tetap ada.

Cara memeriksa semuanya sehat

```
cd lokalboost-api
npm test                                  # 53 tes unit
npm run seed && npm run dev               # terminal terpisah
npm run asap                              # 69 pemeriksaan ke server hidup
API_URL=https://alamat npm run asap       # bisa diarahkan ke server sungguhan
```

Panduan presentasi lengkap ada di `DEMO.md` di akar repo. Langkah penerbitan ada di `DEPLOY.md`.

Lihat **LokalBoost — arsitektur & fitur** dan **LokalBoost — rencana pengembangan**.

Rencana Pengembangan

Diurutkan dari yang paling berdampak per usaha yang dikeluarkan.

Melatih AI-nya — apa artinya sebenarnya

Sering disalahpahami, jadi perlu dicatat baik-baik.

Make.com / Zapier / n8n bukan alat melatih AI. Itu alat otomasi alur kerja — menyambungkan aplikasi dan menjalankan langkah yang sudah kamu susun. Tidak ada yang belajar.

Claude tidak bisa dilatih. Ia model yang di-hosting Anthropic. Yang bisa diperbaiki hanya instruksinya (`SISTEM_NASKAH` dan `SISTEM_LAPORAN` di `services/ai.js`).

Yang benar-benar bisa disetel adalah dua fitur algoritma, karena kecerdasan keduanya sepenuhnya berupa **sepuluh angka**:

- 6 bobot matchmaker di `services/matchmaker.js` (niche 30, lokasi 25, rating 20, rekam jejak 10, jangkauan 10, ketersediaan 5)
- 4 ambang anti-fraud di `config.js` (`AF_DURASI_MIN`, `AF_MAKS_VIEW_IP`, `AF_JENDELA_ULANG`, `AF_AMBANG_Z`)

Siklus pelatihannya:

1. Platform dipakai; orang mengambil keputusan nyata (admin memutus sengketa, UMKM memilih kreator).
2. Sistem menyimpan keputusan itu sebagai jawaban benar.
3. Halaman **Ketepatan AI** di ruang admin menghitung aturan mana yang sering salah dan rekomendasi mana yang sering meleset.
4. **Kamu** menggeser angkanya berdasarkan bukti.

Contoh nyata yang sudah terjadi: aturan IP-berulang tercatat salah 31,5% → berarti `maksViewPerIp: 3` terlalu galak → naikkan ke 5.

> Ini terdengar kurang canggih dibanding "model yang belajar sendiri", tapi justru lebih kuat di depan juri: setiap keputusan sistem bisa dijelaskan alasannya. Model yang dilatih otomatis tidak bisa menjelaskan kenapa ia menolak tayangan seseorang — dan untuk platform yang memegang uang orang, itu masalah besar.

Yang paling layak dikerjakan berikutnya

1. Tutup 2FA penarikan (kecil, dampak besar)

`escrow.js` hanya memeriksa `kodeOtp` tidak kosong. Cocokkan ke tabel `otp` seperti yang sudah dilakukan `/otp/verifikasi`. Perkakasnya sudah ada semua — tinggal dipakai. Ini lubang keamanan nyata di jalur uang.

2. Ubah & lupa kata sandi

Belum ada sama sekali. Alur lupa-kata-sandi bisa memakai infrastruktur OTP yang sudah jadi: kirim kode → verifikasi → izinkan set kata sandi baru. Ubah kata sandi cukup satu endpoint bertoken yang meminta sandi lama.

3. Skrip penyetel yang mengusulkan angka

Setengah langkah menuju otomatis tanpa kehilangan kendali: baca laporan ketepatan, lalu **usulkan** ambang baru — misalnya "*naikkan `maksViewPerIp` dari 3 ke 5; perkiraan salah-saring turun 31,5% → 8%*" — dan kamu yang menyetujui. Ini jawaban paling meyakinkan untuk pertanyaan juri "AI-nya belajar dari mana?".

4. Nyalakan AI generatif

Isi `ANTHROPIC_API_KEY` di `.env`. Perlu diuji sungguhan karena jalur LLM-nya belum pernah dieksekusi — `try/catch` menjatuhkannya ke template tanpa gagal, jadi kesalahan bentuk panggilan API hanya terlihat dari baris `[AI] … memakai template` di log. Ada biaya per panggilan; template tetap jadi cadangan kalau internet mati saat presentasi.

Kalau proyek ini diteruskan setelah lomba

Penerbitan. Butuh proses hidup terus + disk permanen. Pilihan realistis: Railway Hobby (~$5/bln, seluruh konfigurasi sudah siap dan teruji) atau Northflank gratis (wajib kartu untuk verifikasi). Setelah backend online: pasang `VITE_API_URL` di Vercel, **deploy ulang** (Vite menanam nilainya saat build), lalu buktikan bundelnya benar-benar memuat `/api/`.

Payment gateway — Midtrans atau Xendit untuk pasar Indonesia. Titik integrasinya sudah terisolasi di `escrow.js`, jadi tidak perlu membongkar logika uangnya.

Penyimpanan video — Cloudflare R2 atau S3. Folder lokal tidak akan bertahan di hosting mana pun tanpa disk permanen, dan menyajikan video lewat Express boros.

Speech-to-text sungguhan — Whisper untuk Auto-Subtitle, menggantikan segmentasi naskah.

SMS — Twilio/Vonage kalau pendaftaran lewat nomor HP mau dihidupkan lagi. Jangan hidupkan opsinya sebelum penyedianya ada.

Postgres — hanya kalau butuh lebih dari satu replika. SQLite adalah satu berkas di satu disk; dua replika berarti dua salinan yang saling menimpa. Selama satu replika cukup, SQLite justru menghilangkan seluruh

kelas bug async pada transaksi keuangan.

Verifikasi NIB sungguhan — lewat API pemerintah, menggantikan pencatatan manual admin.

Lihat **LokalBoost — arsitektur & fitur** dan **LokalBoost — status & yang belum lengkap**.